

Firewalls



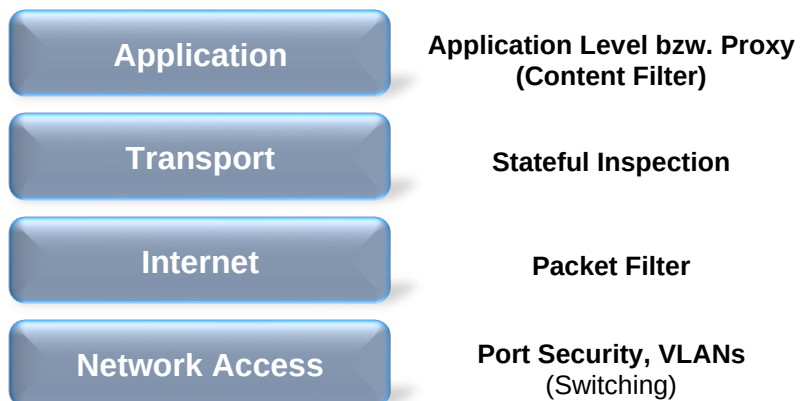
Geschichte

In der Anfangszeit des Internets waren Netzwerkangriffe weitgehend unbekannt. 1988 wurde von Robert Morris der erste Computerwurm programmiert, dieser sich unter Ausnutzung von Unix-Diensten (z.B. sendmail, finger) selbständig verbreitete und ca. 6000 Rechner lahmlegte (ca. 10% des weltweiten Netzes). Bereits 1985 wurden in Routern der Firma Cisco die ersten Packet Filter implementiert, und inzwischen sind Firewalls zum Schutz von Rechnersystemen und Netzwerken so unverzichtbar geworden, wie beim täglichen Arbeiten der Internetzugang und die Online-Präsenz eines Unternehmens selbstverständlich sind.

Funktion

Die Firewall ist eine Schwelle zwischen zwei Netzwerken, die den Verkehr anhand eines definierten Regelwerkes (Policies) filtert und ggf. erkannte Ereignisse protokolliert.

Diese Analyse von Telegrammen z.B. nach Adressen und/oder Diensten (Ports) kann je nach Firewall-Implementierung auf jeder Protokoll-Ebene erfolgen.



Für Unzulänglichkeiten von Betriebssystemen oder Anwendungen sind Firewalls so wenig zuständig wie für die Fahrlässigkeit von Benutzern. Ebenso hat sie keine Ahnung davon, was ein Angriff ist – sie filtert lediglich den Verkehr anhand ihrer Regeln.

Positionierung von Firewalls

1. Personal Firewall



Personal- bzw. Desktop-Firewalls sind (oft kostenlose) Programme, die lokal auf dem zu schützenden Rechner installiert sind. Sie schützen ihn vor unbefugtem Zugriff und unerlaubter Kommunikation, den Netzwerkverkehr anderer Stationen können sie nicht kontrollieren. Je nach Implementierung ist eine anwendungs- oder benutzerspezifische Filterung möglich.

Von der Kombination mehrerer Personal Firewalls auf einem System wird abgeraten: Ohne Zugewinn an Sicherheit wird möglicherweise der erwünschte Datenverkehr erschwert und gleichzeitig die Anzahl der Sicherheitslücken erhöht.

Die Windows-Firewall:

- Eingehende Verbindungen werden in Abhängigkeit des Profils (Privat, Öffentlich, Domäne) und der entsprechenden Regeln gesperrt oder zugelassen
 - Ausgehende Verbindungen werden grundsätzlich zugelassen, können aber auch geregelt werden.
- Hilfreiches Tool: "Windows Firewall Control"

2. Netzwerk-Firewall



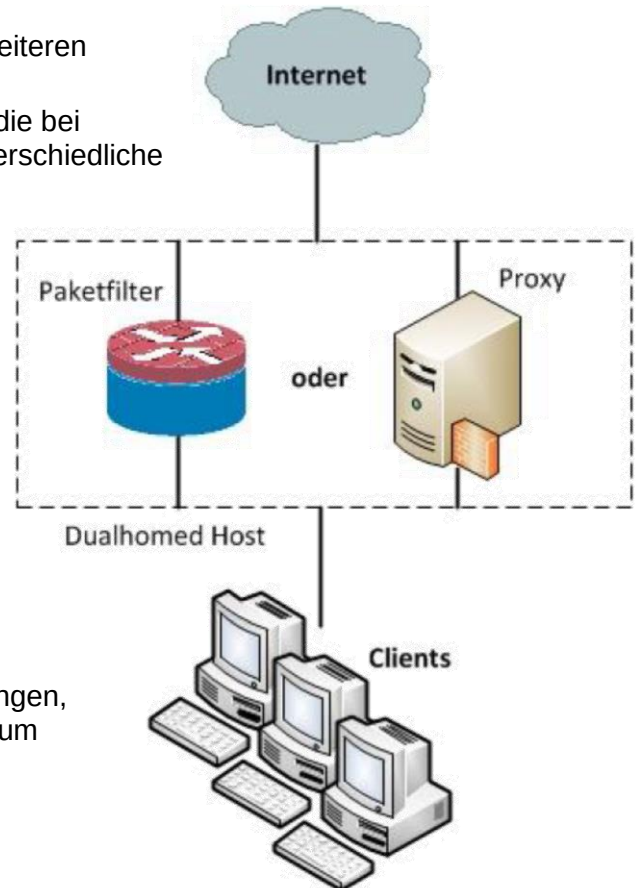
Üblicherweise wird ein Gerät Netzwerk- oder Hardware-Firewall genannt, wenn es sich um ein dediziertes Gerät handelt, das mindestens zwei Netze bzw. Netzsegmente voneinander trennt. Meist handelt es sich um "Routing-Firewalls", d.h. die Netzsegmente sind wie bei einem Router gekoppelt.

Überlegungen:

- In den Schutzbereichen darf es keinesfalls einen weiteren (ungeschützten) Internetzugang geben!
- Redundanz und Mehrstufigkeit erhöht die Hürden, die bei einem Einbruch zu überwinden sind (möglichst unterschiedliche Fabrikate verwenden)
- Interne Bereiche mit unterschiedlichen Sicherheitsanforderungen lassen sich durch zusätzliche Firewalls abtrennen

Die Hardware-Firewall besitzt mehrere Netzwerkschnittstellen, an denen jeweils die zu trennenden Netze angeschlossen sind. Dabei unterscheidet man meist vier Netzwerkzonen:

- Externes Netz (WAN), meist das Internet, aber auch Kundennetze → Nicht vertrauenswürdig
- Internes Netz (LAN) → vertrauenswürdig
- Management Netz: Besondere Sicherheitsanforderungen, weil von hier aus Zugriffe zur Systemkonfiguration, zum Einspielen von Sicherheitsrichtlinien und anderer Verwaltungsfunktionen erfolgen

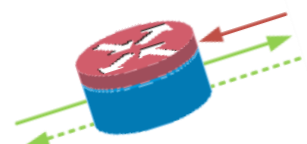


Grundstrategien

- Geschlossener Ansatz (Whitelist-Strategie):
→ **Alles was nicht ausdrücklich erlaubt wurde ist verboten**
- Offener Ansatz (Blacklist-Strategie):
→ **Alles was nicht ausdrücklich verboten wurde ist erlaubt**

Bei der Firewallkonfiguration zu beachten:

- Filterregeln werden in ihrer Reihenfolge nacheinander abgearbeitet!
 - Bsp. Blacklist: Am Anfang stehen konkrete adress- oder dienstbezogene konkrete Verbote (Deny) oder Erlaubnisse (Pass), die letzte Regel lautet immer "Deny All"
 - Erteilt man z.B. einem Adressbereich/Subnet den Zugriff und blockiert in einer späteren Regel eine bestimmte Einzeladresse dieses Netzes, dann bleibt diese Blockierung ohne Effekt
- Eine Session benötigt zwei Filterregeln in der Whitelist:
Abgehend und Ankommend!



Typische Probleme

- Auch Firewalls haben Bugs und Sicherheitslücken → stetige Aktualisierung wichtig!
- Überforderung von Nutzern bei der Konfiguration
- Manche Nutzer wähnen sich in Sicherheit und werden nachlässig
- Bei zu vielen Event-Meldungen schaut keiner mehr hin

Anforderungen

- Konfigurierbare Filterfunktionen (Policies) für Protokolle u. Dienste
- Konfigurierbare Reaktionen bei Regelverletzungen
- Userunterstützung z.B. durch sinnvolle Vorkonfigurationen
- Update- und Support-Funktionen

Firewall-Technologien

1. Paketfilter

Die "statische" Filterung der Datenpakete anhand von Quell-/ Ziel-Adresse und -Port ist die klassische Grundfunktion einer Firewall, die den ein-/ausgehenden Verkehr filtert nach:

- IP-Adressen
- TCP-/UDP-Ports
- Protokoll-Typ (TCP, UDP, ICMP)
- Flags und bei ICMP Type und Code



Die Paketfilterung lässt sich weitgehend bereits auf einem Router realisieren, der mit **ACLs (Access Control List)** umgehen kann.

Schwachpunkt von Paketfiltern:

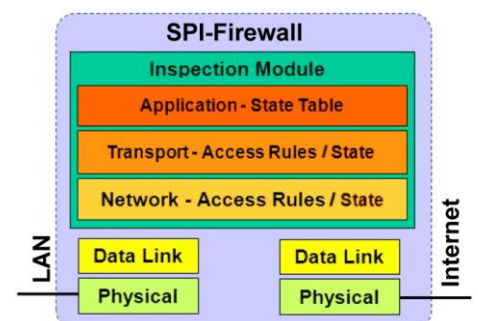
- "stateless"-Filterung (zustandslos) → Jedes Paket wird isoliert betrachtet, nicht aber im Kontext mit vorangegangenen Paketen. Nur anhand der Header-Informationen wird entschieden, ob es zulässig ist oder nicht – kein Hindernis also für gefälschte Adressen und Portnummern.
- Eine inhaltliche Prüfung der Anwendungsprotokolle bzw. Dateninhalte findet nicht statt

2. Stateful Packet Inspection (SPI)

Bei der "dynamischen" Paketfilterung wird der Zustand (State) einer Verbindung bzw. Session überwacht und für das einzelne Paket beurteilt, ob es in diesen Kontext passt (Verbindungsaufbau, Adressen, Ports, Flags und Funktionen von Anwendungsprotokollen).

Dies erlaubt gleichzeitig, für eine zulässige Verbindung auch die benötigte Rückrichtung automatisch "freizuschalten".

Die SPI dürfte der derzeit meistverwendete Firewall-Typ für Rechnersysteme sein.



3. Verbindungsoptionen

- **Routed Firewall Mode (Router):**

In diesem Modus ist die Firewall ein **gerouteter Hop**, der **im Trace Route sichtbar** ist. Die Firewall arbeitet als Layer-3-Gerät. Jede ihrer Schnittstellen ist einem anderen logischen Subnetz zugewiesen. Wer nachträglich in ein bestehendes Netz eine Firewall im Routed Mode einfügen will, muss daher dessen Infrastruktur entsprechend anpassen.

Die Pakete werden zwischen den Subnetzen auf Grundlage vorher festgelegter Regeln (z.B. ACLs) weitergeleitet. Die Routed Firewall dient als Standard-Gateway für Hosts, die sich in den abgeschirmten Subnetzen befinden.

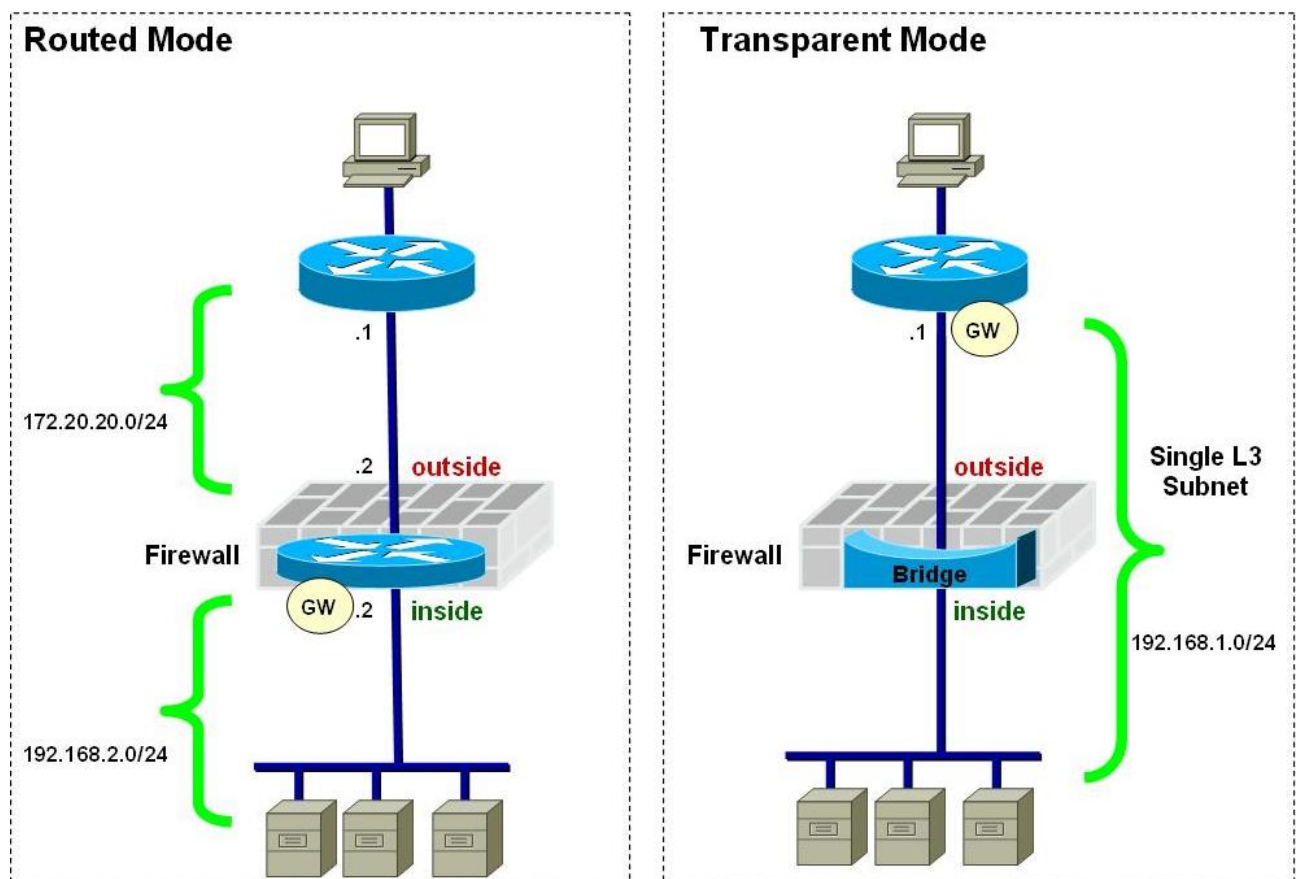
In der Abbildung hat die innere Schnittstelle die IP-Adresse 192.168.2.2, während die äußere die Adresse 172.20.20.2 verwendet. Da die Hosts durch die Firewall miteinander verbunden sind, müssen die Rechner auf der Innenseite die Adresse 192.168.2.2 als ihr Default-Gateway konfigurieren, um Ziele außerhalb zu erreichen.

- **Transparent Firewall Mode (Bridge):**

In diesem Modus arbeitet die Firewall als Bridge auf OSI-Schicht 2 (besser bekannt unter dem Begriff Switch). Als **Layer-2-Gerät** wird sie von den angeschlossenen Geräten nicht als Layer-3-Hop wahrgenommen und ist **im Trace Route unsichtbar** („Stealth-Firewall“). Man spricht deshalb auch von einer transparenten Firewall.

Als Firewall wertet die Bridge auch höhere Protokollschichten aus (IP-Adressen, TCP-Ports). Davon bemerken die beteiligten Hosts jedoch nichts, wenn sie nur erlaubte Pakete versenden.

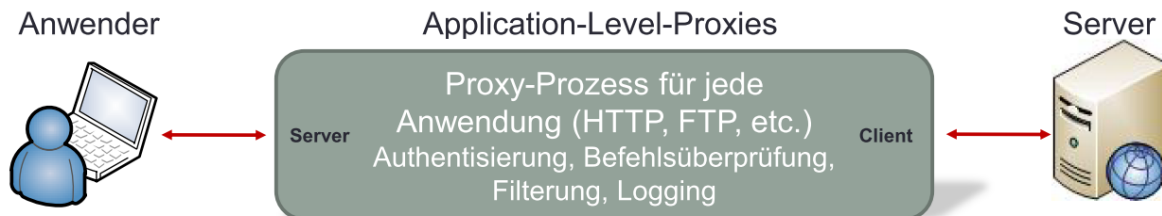
In der Abbildung sind die beiden dargestellten Schnittstellen mit demselben L3-Subnetz verbunden, und die internen Hosts verwenden den externen Router (192.168.1.1) als ihr Gateway, um externe Ziele zu erreichen. Der große Vorteil ist, dass die Firewall in das Netzwerk eingefügt werden kann, ohne das bestehende IP-Adressierungsschema ändern zu müssen (was in verschiedenen Situationen sehr praktisch sein kann).



4. Application-Level Firewall / Proxy

Ein Proxy-Server ruft stellvertretend für seine Stationen Daten aus dem Internet ab, speichert diese zwischen und verschickt Kopien davon an die anfragenden Stationen. Es gibt somit keine direkte Verbindung mehr von einem Client zu einem Server.

Proxies arbeiten üblicherweise dienstspezifisch (z.B. http-Proxy), andernfalls kommen "Circuit-Level Proxies" zum Einsatz (generische Proxies ohne Überwachung des Anwendungsprotokolls).



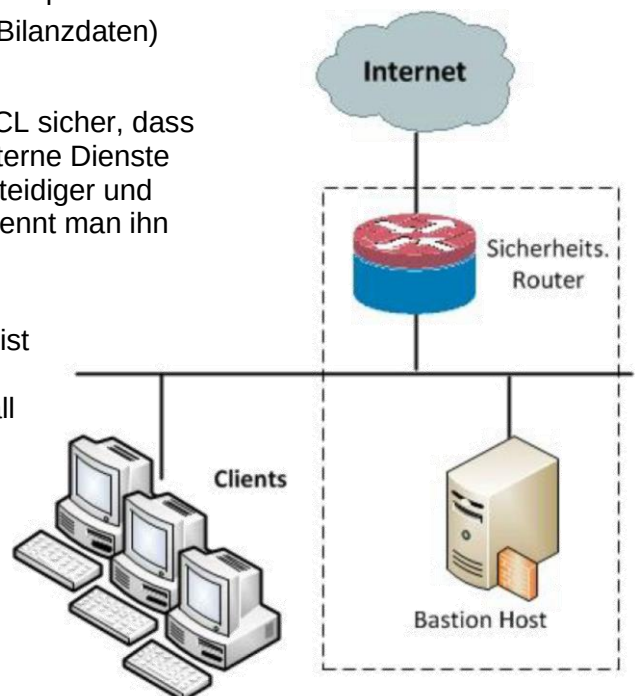
Vor der Datenauslieferung kann der Proxy nicht nur einzelne Pakete kontrollieren (Protokolldaten), sondern die übertragenen Nutzinhalt bzw. ganze Dateien scannen → **Content-Filterung** auf **Anwendungsebene**. Diese Aufgabe fordert Ressourcen, weshalb ein Proxy / Application-Level Firewall schnell zum Flaschenhals im Netz werden kann!

Beispielhafte Aufgabenstellungen:

- Blockieren unerwünschter Anwendungsprotokolle oder Aktivitäten (z.B. Filesharing)
- Sperren von unerwünschten Webseiten bzw. Inhalten anhand von Schlüsselwörtern
- Abfangen von Viren, Trojanern oder ActiveX-/ JavaScript-Controls in Webseiten
- Herausfiltern von vertraulichen Informationen (z.B. Bilanzdaten)

Meist stellt ein zusätzlicher Sicherheitsrouter z.B. per ACL sicher, dass einzig der "**Application Level Gateway**" (Proxy) auf externe Dienste zugreifen kann. In diesem Fall, wo er den alleinigen Verteidiger und Kontaktpunkt eines LANs zum Rest der Welt darstellt, nennt man ihn auch "**Bastion Host**".

Achtung: Indem ein Proxy stellvertretend Inhalte abrufen, ist als Absender nur noch die IP-Adresse des Proxys sichtbar (Anonymisierung). Eine nachgeschaltete Firewall kann anhand dieser Adresse nicht mehr erkennen, ob eine Verbindung legitim ist oder nicht! In diesem Fall muss der Zugang zu den Inhalten z.B. durch Authentifizierung auf dem Proxy gesteuert werden.



3. Demilitarisierte Zone (DMZ)

Sicherheitsrisiko:

In einem Firmennetz befindet sich ein Server, dessen Dienste auch der öffentlichen Kundschaft zugänglich sein sollen (z.B. Web-, FTP-, Mail-Server). Entsprechende Dienstanfragen müssen von außen herein gelassen werden, z.B. durch Freigabe von Port 80 (http) auf der Firewall. Ein unliebsamer Besucher befindet sich damit sogleich auf einem Rechner im Firmennetz und kann über diverse Sicherheitslücken versuchen, sich von dieser Position aus Zugang zu weiteren Ressourcen zu verschaffen.

Lösung:

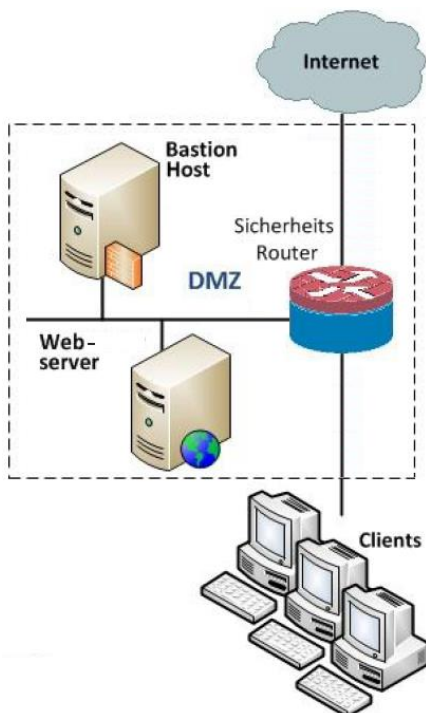
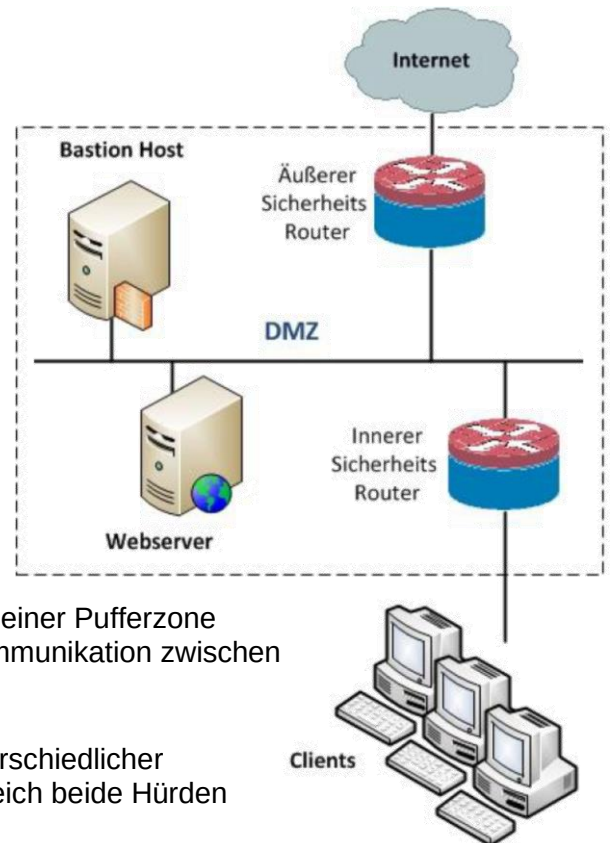
- **Zweistufige DMZ:**

Die Server werden von außen und innen zugänglich in einer Pufferzone zwischen zwei Firewalls positioniert, auf denen die Kommunikation zwischen LAN und WAN getrennt kontrolliert werden kann.

Empfehlenswert ist die Verwendung von Firewalls unterschiedlicher Hersteller, damit im Fall von Sicherheitslücken nicht gleich beide Hürden überwunden werden.

- **Einstufige DMZ:**

Es handelt sich im Grunde um einen Router, der mit 3 Interfaces die Bereiche LAN, DMZ und WAN voneinander trennt und den Verkehr per ACLs kontrolliert. Unter Sicherheitsaspekten handelt es sich um einen kostengünstigen Kompromiss.



Beispiel für DMZ-Filterregeln:

- Aus dem Internet zum Mailserver in der DMZ ist Mail-Transfer (SMTP) erlaubt
- Der Mailserver darf aus der DMZ in das öffentliche Netz Mails verschicken (SMTP) und DNS-Anfragen stellen
- Vom lokalen Netz aus dürfen Mails abgeholt und verschickt werden (SMTP, POP3, IMAP), Administrations-Dienste (SSH, Remote Desktop, Backup) zum Mailserver sind erlaubt
- Alle anderen Pakete in die bzw. aus der DMZ werden in einer Logdatei registriert und danach verworfen

Vorsicht:

Bei DSL-Routern reden manche Hersteller ebenfalls von "DMZ" oder "DMZ-Unterstützung", meinen damit aber einen "**Exposed Host**". Ist dieser konfiguriert, dann leitet der Router allen Verkehr aus dem Internet, der nicht zu einer (von innen aufgebauten) Session gehört, an einen bestimmten internen Rechner weiter. Damit macht man sich für User aus dem Internet zwar erreichbar, handelt sich aber das oben erwähnte hohe Sicherheitsrisiko ein!

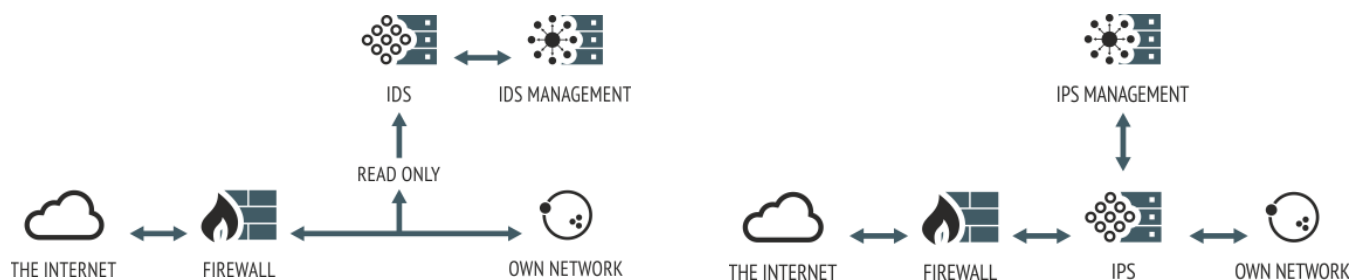
4. Intrusion Detection System (IDS) / Intrusion Prevention System (IPS)

Viele Angriffe werden von Firewalls nicht erkannt, denn prinzipiell weiß eine Firewall überhaupt nicht, was ein "Angriff" ist: Spricht keine der Filterregeln dagegen, so wird z.B. das Paket mit der geklauten (gespooften) Adresse durchgelassen!



Ein **IDS** (z.B. Snort) überwacht den Systemzustand und den Datenaustausch anhand der Regeln, nach denen eine "normale" Kommunikation abläuft. Es "kennt" auch die typischen Netzaktivitäten, mit denen bekannte Angriffsmethoden vorbereitet werden und ablaufen (→ Ständige Aktualisierung!). Durch permanentes Monitoring und Analyse des Netzwerkverkehrs werden abnormale Ereignisfolgen identifiziert, die vom Normalbetrieb abweichen, und an das IDS-Management gemeldet.

Ein IDS schreibt nur Logfiles und schlägt ggf. Alarm, um Folgemaßnahmen einzuleiten. Aus der Kombination von IDS und Firewall ergibt sich ein **IPS** (Intrusion Prevention System), welches aktiv in das Geschehen eingreift, um erkannte Angriffe abzublocken.



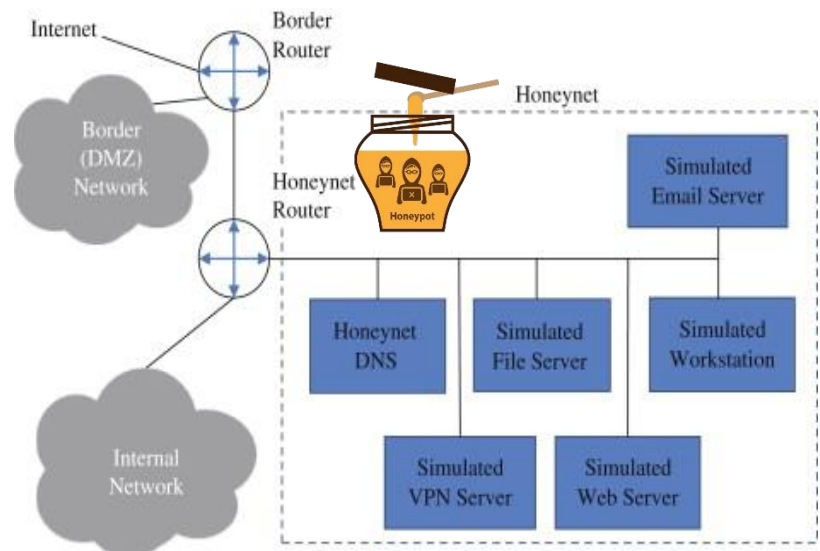
Desktop-IDS: "ThreatFire"

5. Honeypot



Die "Klebefalle" lockt den Angreifer an bzw. lenkt ihn ab von Produktivrechnern, damit seine Aktivitäten analysiert und abgewehrt werden können.

Um Aufmerksamkeit auf sich zu ziehen besteht der Honeypot aus einem Rechner, der absichtlich bestimmte Sicherheitslücken aufweist. Auf diesem dürfen sich keine wirklich wichtigen Daten befinden, dennoch sollte er für den Angreifer einigermaßen "interessant" aussehen.



HoneyMap: Cyber-Attacken in Echtzeit beobachten! <https://www.sicherheitstacho.eu>

Weitere Links zum Thema Wirewalls:

- <https://www.elektronik-kompndium.de/sites/net/0907241.htm>
- <https://kompndium.infotip.de/netzwerkkomponenten-firewalls-und-dmz.html>
- Youtube-Video zum Thema DMZ: <https://www.youtube.com/watch?v=bzbdK8f6Y1U>